

TAREA BRS02

Diseños de planes de securización

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: Tarea de investigación	3
Respuestas 1	3

Detalles de la tarea de esta unidad

Caso práctico

*El alumno debe identificar, en este **supuesto**, qué elementos/decisiones/acciones no cuadran con unas prácticas correctas de los planes de securización que pueden provocar problemas.*

Apartado 1: Tarea de investigación

Una vez que conoces los diferentes modelos para aplicar ciberseguridad en una organización, en base al supuesto planteado deberás:

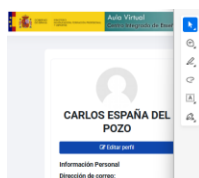
- Identificar qué elementos/decisiones/acciones no cuadran con unas prácticas correctas de los planes de securización.
- Ofrecer las mejores soluciones a los problemas previos.

Respuestas 1

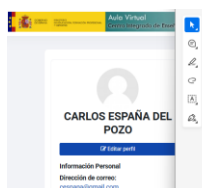
Después de analizar La empresa ficticia, “**Venus SA**” y el fallido plan de modernización de la clínica del CEO puedo indicar que:

Las decisiones o acciones que no cuadran con buenas prácticas de seguridad son las siguientes:

- Ubicación del servidor
 - “El servidor se alojará en el cuarto destinado a guardar los productos y herramientas de limpieza.”
- Concentración de servicios en un mismo servidor
 - “Con el fin de reducir costes tanto el programa gestor como la página web corporativa se ubican en el mismo servidor.”



- La herramienta que gestiona informes, nóminas y proveedores ha sido desarrollada ex profeso para Venus SA.
- Para la página web corporativa se ha utilizado un gestor de contenidos o CMS de código abierto.
- El servidor se alojará en el cuarto destinado a guardar los productos y herramientas de limpieza.
- Como personal de mantenimiento de la herramienta y la página web se dará una formación al recepcionista de clínica.
- Todos los equipos serán configurados para que los usuarios puedan ser administrados por los propios usuarios.

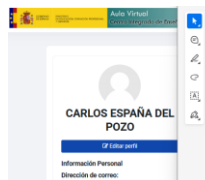


- Los términos de este contrato se aceptan al suscribirse para suscribirse una suscripción para aceptar los términos además garantizar costes y plazos.
- Transcurrido no más de un mes la empresa desarrolladora ha terminado y deciden presentar al CEO de Venus SA, los resultados de su trabajo. Para ello pactan una reunión en la que los principales puntos tratados fueron:
- Con el fin de reducir costes tanto el programa gestor como la página web corporativa se ubican en el mismo servidor.
 - La herramienta que gestiona informes, nóminas y proveedores ha sido desarrollada ex profeso para Venus SA.
 - Para la página web corporativa se ha utilizado un gestor de contenidos o CMS de código abierto.
 - El servidor se alojará en el cuarto destinado a guardar los productos y herramientas de limpieza.
 - Como personal de mantenimiento de la herramienta y la página web se dará una formación al recepcionista de clínica.

- Problema: Una vulnerabilidad de la web puede afectar a datos internos; falta de separación de entornos.

- Privilegios excesivos a usuarios

- “Todos los equipos serán configurados para que los usuarios puedan ser administrados por los propios usuarios.”

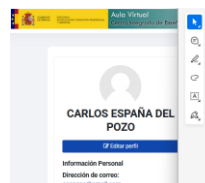


- La herramienta que gestiona informes, nóminas y proveedores ha sido desarrollada ex profeso para Venus SA.
- Para la página web corporativa se ha utilizado un gestor de contenidos o CMS de código abierto.
- El servidor se alojará en el cuarto destinado a guardar los productos y herramientas de limpieza.
- Como personal de mantenimiento de la herramienta y la página web se dará una formación al receptionista de clínica.
- Todos los equipos serán configurados para que los usuarios puedan ser administrados por los propios usuarios.

- Problema: Los usuarios pueden instalar software malicioso, comprometiendo seguridad.

- Personal no cualificado como responsable técnico

- “Como personal de mantenimiento de la herramienta y la página web se dará una formación al receptionista de clínica.”

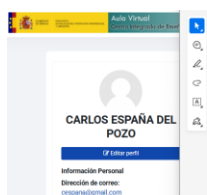


- La herramienta que gestiona informes, nóminas y proveedores ha sido desarrollada ex profeso para Venus SA.
- Para la página web corporativa se ha utilizado un gestor de contenidos o CMS de código abierto.
- El servidor se alojará en el cuarto destinado a guardar los productos y herramientas de limpieza.
- Como personal de mantenimiento de la herramienta y la página web se dará una formación al receptionista de clínica.
- Todos los equipos serán configurados para que los usuarios puedan ser administrados por los propios usuarios.

- Problema: Riesgo de errores humanos, falta de soporte profesional.

- Digitalización de historiales sin control

- “Le recomiendan que la informatización de los historiales antiguos la haga el personal interno, como el receptionista, ya que el proceso es bastante sencillo”



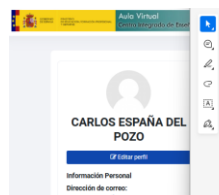
- Le recomiendan que la informatización de los historiales antiguos la haga el personal interno, como el receptionista, ya que el proceso es bastante sencillo y principalmente lo que hay que hacer es escanear documentos.

El CEO decide dar luz verde, para que la actualización sea lo menos traumática posible. Esta se realizará durante el fin de semana así como la formación de los empleados. Llegado el lunes, el receptionista comienza a digitalizar todos los informes, el personal de recursos humanos hace lo propio con las nóminas y el CEO con los proveedores. Después de una semana de arduo trabajo, sobre todo del receptionista, el sistema está listo para ser utilizado por los doctores.

A los pocos días de uso de la herramienta esta deja de funcionar correctamente y constantemente se producen caídas del servicio pese a los intentos del receptionista-técnico de sistemas por solucionarlo. Tanto los doctores, como el personal de RR HH

- Problema: Riesgo de exposición de datos sensibles, falta de trazabilidad y control de acceso.

- Falta de respaldo y continuidad del negocio
 - “A los pocos días de uso de la herramienta esta deja de funcionar correctamente y constantemente se producen caídas.”



Llegado el lunes, el recepcionista comienza a digitalizar todos los informes, el personal de recursos humanos hace lo propio con las nóminas y el CEO con los proveedores. Después de una semana de arduo trabajo, sobre todo del recepcionista, el sistema está listo para ser utilizado por los doctores.

A los pocos días de uso de la herramienta esta deja de funcionar correctamente y constantemente se producen caídas del servicio pese a los intentos del recepcionista-técnico de sistemas por solucionarlo. Tanto los doctores, como el personal de RR.HH. y el CEO deben volver a hacer su trabajo como lo habían estado haciendo hasta antes de la informatización de la clínica.

- Problema: No existen backups ni plan de recuperación; afecta la continuidad del negocio.

Las mejores soluciones a los problemas indicados son los siguientes:

- Ubicar el servidor en un cuarto técnico con control de temperatura, acceso restringido, protección contra incendios y humedad, siguiendo buenas prácticas de seguridad física (ISO 27001, NIST).
- Separar entorno interno y web pública en servidores distintos; aplicar firewalls y segmentación de red.
- Implementar control centralizado de usuarios, asignando privilegios mínimos según función (principio de mínimo privilegio).
- Contar con personal de TI cualificado o contratar soporte externo certificado, y que el recepcionista solo realice tareas básicas de operación.
- Implementar procedimientos seguros de digitalización:
 - Escaneo controlado.
 - Acceso restringido a documentos.
 - Registro de quién accede a qué información.
- Implementar:
 - Backups periódicos en ubicación segura.
 - Plan de recuperación ante desastres.
 - Monitoreo de disponibilidad del sistema.

Como ultima recomendación, pero no menos importante recomendaría:

Elaborar un **Plan director de Ciberseguridad** que incluya:

- Análisis de riesgos y clasificación de activos.
- Políticas de seguridad física, lógica y operativa.
- Procedimientos de gestión de usuarios y privilegios.
- Estrategias de backup, continuidad de negocio y recuperación ante desastres.
- Plan de formación y concienciación para el personal.
- Evaluación periódica y auditorías de seguridad.